Note de synthèse – Audit ISO/IEC 27001:2022 et évaluation NIST CSF 2.0

Diagnostic cybersécurité de la PME industrielle Alsa-Tech

Groupe : Chloé, Nathan, Camille – BUT 3 Cybersécurité, UHA Colmar – Diagnostic pédagogique sur scénario, ne valant ni audit de certification ni attestation de conformité.

1. Résumé exécutif

Rédaction : Chloé

Mandat : la direction d'Alsa-Tech souhaite savoir quelles actions engager sur douze mois pour réduire son exposition à un arrêt de production d'origine cyber, structurer son management de la sécurité et mieux répondre aux attentes de ses donneurs d'ordre.

Sur la base des preuves examinées, le diagnostic met en évidence une sécurité construite autour de l'informatique de gestion, alors que le risque majeur se situe dans l'atelier. Le réseau d'automates et la télémaintenance sont hors du périmètre de sécurité déclaré. Trois risques dominent : une intrusion par le compte VPN partagé et sans MFA du prestataire d'automatisme (C1), la propagation d'un rançongiciel du poste d'ingénierie vers le SCADA par une règle pare-feu trop large (C2), et l'impossibilité de redémarrer les lignes faute de sauvegarde testée des configurations d'automates (C3). Ces écarts viennent d'une gouvernance non formalisée : aucun responsable du risque cyber, aucun seuil d'acceptation, aucun indicateur (C6, C7).

Côté NIST, aucun des 25 résultats évalués n'est atteint : 18 sont non atteints et 7 partiellement atteints. L'organisation se situe au Tier 1 (Partiel). Côté ISO, la grille retient sept non-conformités majeures et une mineure.

Décision attendue : nommer un responsable du risque cyber et valider un plan de cinq actions sur douze mois, dont trois engagées sous quatre mois (A1 à A3) pour un coût majoritairement interne ou modéré.

2. Périmètre et méthode

Rédaction : Nathan

2.1 L'organisation étudiée et le périmètre

Alsa-Tech est une PME industrielle fictive de Mulhouse (85 salariés) qui produit des pièces pour l'automobile. Ses activités critiques sont la planification, la fabrication, le contrôle qualité, l'expédition et la facturation. Le diagnostic couvre le réseau bureautique, l'ERP, les postes CAO, le réseau industriel, les postes d'ingénierie, le SCADA, les automates, les accès distants des prestataires et les sauvegardes associées. Les systèmes RH hébergés en SaaS ne sont traités que comme dépendance fournisseur.

Ce périmètre inclut volontairement la télémaintenance et le réseau d'automates, pourtant exclus du périmètre SMSI déclaré par l'entreprise (E02) : cet écart est lui-même un constat (C5).

2.2 Méthodologie et traçabilité

Le diagnostic repose sur les seize pièces du dossier (E01 à E16) et sur l'entretien simulé de l'Annexe A du sujet. Chaque constat suit la chaîne critère, preuve, fait, risque, qualification, action, et chaque information est qualifiée en fait établi, déclaration, hypothèse ou information manquante. Une réponse d'entretien non corroborée reste une déclaration.

- **ISO/IEC 27001:2022 :** revue des clauses 4 à 10 (22 sous-clauses) et de 15 contrôles de l'Annexe A sélectionnés selon les menaces prioritaires (rançongiciel, accès distant, fournisseur compromis). Qualifications selon les repères du sujet (NC majeure, NC mineure, observation, opportunité).
- **NIST CSF 2.0 :** profil actuel et cible à 12 mois sur 25 résultats, notés sur une échelle pédagogique locale de 0 à 4. Cette échelle ne correspond pas aux Tiers, évalués séparément pour l'organisation entière.

2.3 Analyse critique des modèles et limites

Les modèles fournis contenaient plusieurs identifiants du CSF 1.1 qui n'existent plus dans le CSF 2.0 (PR.AC, PR.PT, PR.IP, DE.DP, ID.BE, RC.IM notamment) et un code inexistant (GV.IM, l'amélioration relevant d'ID.IM). L'équipe a donc travaillé sur les 25 résultats CSF 2.0 du sujet et a corrigé la table de correspondance ISO/NIST. Le modèle ISO ne couvrant ni l'Annexe A ni la qualification des écarts, ces éléments ont été ajoutés.

Limites : aucun entretien réel ni visite sur site ; surveillance physique (A.7.4) non évaluable faute de pièce ; étendue de la compromission d'août 2026 inconnue faute d'analyse ; délai d'arrêt toléré par les clients et compatibilité des automates avec le MFA ou les correctifs non documentés.

3. Constats prioritaires

Rédaction : Camille

3.1 Synthèse croisée des constats (ISO/IEC 27001:2022 et NIST CSF 2.0)

Sur la base des preuves examinées, le diagnostic met en évidence huit écarts prioritaires (sept non-conformités majeures et une non-conformité mineure au sens des repères du sujet) qui exposent Alsa-Tech à un arrêt

prolongé de production, à une perte de propriété intellectuelle (plans CAO, paramètres d'usinage) et à un défaut vis-à-vis de ses donneurs d'ordre automobiles. Les scores NIST indiqués sont ceux de l'échelle pédagogique 0-4 (actuel → cible à 12 mois).

Constat factuel	Preuve et statut	Impact métier plausible	Lecture ISO 27001	Lecture NIST CSF 2.0 et priorité
C1 – Accès distants tiers et comptes à privilèges OT non maîtrisés Le compte VPN du prestataire d'automatisme est générique, sans MFA, et reste parfois actif après intervention. Deux comptes administrateurs SCADA sont partagés et hors revue trimestrielle.	**E08** *(fait établi)* **Entretien** *(déclaration sur le maintien actif)*	**Critique :** intrusion directe sur le réseau industriel via le compte prestataire ; aucune imputabilité d'une action arrêtant l'atelier.	**A.5.15, A.5.16, A.5.18** NC majeure	PR.AA-01 (1 → 3) PR.AA-03 (1 → 3) PR.AA-05 (2 → 3) **Haute**
C2 – Segmentation IT/OT défaillante et contradiction documentaire Une règle non justifiée autorise de nombreux flux du poste d'ingénierie (à jour à 60 %) vers le SCADA, alors que la DdA déclare la segmentation « mise en œuvre ».	**E03, E07, E12** *(faits établis)*	**Critique :** mouvement latéral d'un rançongiciel de l'IT ou du poste d'ingénierie vers le SCADA et les automates.	**A.8.22, A.8.20, A.8.8, clause 6.1.3** NC majeure	PR.IR-01 (2 → 3) PR.PS-01 (1 → 3) ID.RA-01 (2 → 3) **Haute**
C3 – Configurations OT ni sauvegardées hors du poste d'ingénierie, ni testées L'ERP est sauvegardé hors ligne et testé (juillet 2025) ; les configurations d'automates ne sont que sur le poste d'ingénierie, jamais restaurées formellement.	**E09, entretien** *(faits établis + information manquante sur la restaurabilité OT)*	**Critique :** point unique de défaillance ; perte des programmes automates et redémarrage des lignes hors des délais clients.	**A.8.13, A.5.30** NC majeure	PR.DS-11 (2 → 3) RC.RP-01 (1 → 3) **Haute**
C4 – Détection OT absente et plan de réponse inopérant Journaux IT gardés 30 jours, SCADA en local, sans corrélation IT/OT ni veille hors heures ouvrées. Plan de réponse en brouillon (nov. 2022), sans séquence d'arrêt OT ni exercice.	**E10, E11, entretien** *(faits établis)*	**Élevé :** attaque nocturne détectée tard ; coupure d'urgence non coordonnée pouvant endommager l'outil ou exposer les opérateurs.	**A.5.24 (NC majeure), A.8.15 (NC mineure)** NC majeure	DE.CM-01 et 09 (1 → 3) RS.MA-01 (1 → 3) **Haute** (RS) / **Moyenne** (DE)
C5 – Périmètre SMSI excluant l'environnement industriel Le périmètre 2024 inclut l'ERP et la bureautique mais exclut la télémaintenance et le réseau d'automates.	**E02, E14** *(faits établis)*	**Élevé :** actifs indispensables à la fabrication laissés hors gouvernance.	**Clause 4.3 (et 4.1, NC mineure)** NC majeure	GV.OC-03 (2 → 3) GV.SC-04 (1 → 3) **Moyenne**
C6 – Rôles SSI, acceptation du risque et revue de politique non formalisés Le responsable IT pilote la SSI sans lettre de mission ; aucun responsable du risque cyber ni seuil d'acceptation ; politique de juin 2023 jamais revue.	**E01, E05, E15, entretien** *(faits établis)*	**Élevé :** flou décisionnel entre direction, IT et production ; acceptation implicite de risques critiques.	**Clauses 5.1, 5.2, 5.3, A.5.2** NC majeure	GV.RR-02 (1 → 3) GV.RM-01 (1 → 3) GV.PO-01 (1 → 3) **Haute**
C7 – Analyse de risques obsolète et pilotage sans KPI Registre de février 2024, rançongiciel classé « moyen » sans hypothèses ; 6 automates sur 10 avec propriétaire ; revue de direction de mars 2026 sans KPI ni suivi d'actions.	**E04, E06, E15** *(faits établis)*	**Modéré à élevé :** sous-évaluation du scénario d'arrêt d'usine et budget non aligné sur la criticité OT.	**Clauses 6.1.2, 6.2, 9.1, 9.3, A.5.9** NC mineure	GV.RM-06, GV.OV-01, ID.AM-01/05, ID.RA-05/06 (1-2 → 3) **Haute**
C8 – Pas d'audit interne récent ni de capitalisation post-incident Aucun audit interne depuis octobre 2023 ; compte de messagerie compromis en août 2026 traité par simple réinitialisation, sans analyse de cause ni RETEX.	**E15, E16** *(faits établis)*	**Élevé :** persistance possible d'un attaquant et dérive durable du SMSI.	**Clauses 9.2, 10.1, 10.2** NC majeure	ID.IM-01 (1 → 3) **Moyenne**

3.2 Points d'attention secondaires et zones d'incertitude

1. **Sensibilisation insuffisante des populations exposées (E13, A.6.3 / PR.AT-01) :** 72 % des permanents mais seulement 35 % des intérimaires formés, aucun exercice de phishing, aucune formation spécifique pour les administrateurs OT (NC mineure ; score NIST 2).
2. **Encadrement cyber des fournisseurs (E14, A.5.19 / GV.SC-04) :** clause générale de confidentialité, sans délai de notification d'incident ni exigence de révocation des accès distants (NC mineure ; score NIST 1).
3. **Éléments impossibles à conclure (information manquante) :** une absence de preuve n'est pas une preuve d'absence. La surveillance physique des ateliers et locaux serveurs (A.7.4) n'apparaît dans aucune pièce et reste une observation à vérifier sur site. L'absence d'analyse de l'incident d'août 2026 (E16) ne permet pas d'exclure une compromission résiduelle.

4. Plan d'amélioration et roadmap 12 mois

Rédaction : Nathan

Pour répondre à la question de la direction et traiter les écarts prioritaires, nous proposons cinq actions réparties en trois phases et dimensionnées pour une PME.

4.1 Actions prioritaires (A1 à A5)

ID	Action et risque traité	Responsables et échéance	Classe de coût et effort	KPI et critère de succès
A1	**Extension du périmètre SMSI, gouvernance et acceptation du risque** Traite C5 et C6.	DG + Resp. IT Échéance : M3	Classe S (temps interne) Effort : faible	Périmètre révisé incluant l'OT ; 100 % des rôles nommés (RACI) ; grille de risques approuvée par la DG.
A2	**Sécurisation des accès prestataires et des comptes à privilèges OT** Traite C1.	Resp. IT + Resp. production Échéance : M3	Classe M (MFA, prestataire) Effort : moyen	100 % des accès VPN distants avec MFA ; comptes SCADA 100 % nominatifs ; désactivation automatique des VPN tiers.
A3	**Sauvegarde déconnectée et test de restauration OT** Traite C3.	Resp. production + Resp. IT Échéance : M4	Classe M (stockage, support OT) Effort : moyen	Configurations d'automates externalisées (règle 3-2-1) ; un test de restauration complet par trimestre.
A4	**Analyse de risques, KPI et revue de direction** Traite C7.	DG + Resp. IT + Resp. qualité Échéance : M6	Classe S (temps interne, outils) Effort : faible	Registre réévalué sur scénarios IT/OT ; tableau de bord KPI trimestriel présenté en revue de direction.
A5	**Supervision IT/OT centralisée, plan de réponse et RETEX** Traite C4 et C8.	Resp. IT + Resp. production + Qualité Échéance : M12	Classe L (sonde, intégration) Effort : important	Logs SCADA et pare-feu centralisés ; procédure d'arrêt OT validée ; un exercice de crise par an ; 100 % des incidents avec RETEX.

4.2 Roadmap d'implémentation

Phase 1 – Stabiliser (0 à 3 mois) : A1 formalisation du périmètre IT/OT et lettre de mission SSI ; A2 MFA sur les accès distants et suppression des comptes SCADA partagés ; amorçage de A3 (externalisation hors ligne des programmes d'automates).

Phase 2 – Structurer (3 à 6 mois) : finalisation de A3 (premier test de restauration d'un automate en fenêtre de maintenance) ; A4 révision du registre des risques et mise en place des KPI ; durcissement des règles pare-feu du poste d'ingénierie (C2) et avenants fournisseurs.

Phase 3 – Consolider (6 à 12 mois) : A5 centralisation des journaux SCADA et IT, procédure d'arrêt OT et exercice de crise ; audit interne annuel (clause 9.2) et revue de direction (clause 9.3).

5. Recommandation stratégique

Rédaction : Chloé

5.1 Trajectoire recommandée : l'approche hybride

ISO/IEC 27001 et le NIST CSF 2.0 ne sont pas équivalents : ISO structure le management de la sécurité et la production de preuves, le NIST exprime des résultats attendus, un état actuel et une cible. Nous recommandons de les combiner en deux temps :

- **0 à 6 mois, piloter avec le profil NIST :** suivre la progression des résultats prioritaires (accès distants, sauvegardes OT, segmentation, rôles) et la présenter à la direction dans un langage simple.
- **6 à 12 mois, structurer avec ISO 27001 :** périmètre incluant l'OT, rôles formalisés, déclaration d'applicabilité sincère, audit interne et revue de direction. C'est la base attendue par des donneurs d'ordre exigeants.

Une certification n'est pas réaliste à douze mois : elle supposerait au moins un cycle complet d'audit interne et de revue de direction, puis l'audit d'un organisme habilité. Ce diagnostic ne permet pas d'affirmer que l'entreprise est certifiable.

5.2 Évolution visée du Tier organisationnel NIST

Tier actuel : Tier 1 (Partiel), avec quelques éléments de Tier 2. La gestion du risque reste réactive : personne n'est formellement responsable de son acceptation (E01, E15), les documents ne sont pas revus (E05, E06, E10) et les pratiques répétables se limitent à l'IT de gestion (E08, E09).

Tier cible à 12-18 mois : Tier 2 (Informé sur les risques). Les pratiques de gestion du risque seront approuvées par la direction, sans être encore généralisées à toute l'organisation. Le Tier caractérise l'organisation entière : il ne se confond pas avec les scores 0-4 du profil.

5.3 Conditions de réussite et arbitrages attendus

La réussite dépend de quatre arbitrages de la direction :

1. **Nommer un responsable du risque cyber** et signer sa lettre de mission, avec l'autorité d'arbitrer entre IT et production (A1).
2. **Valider les seuils d'acceptation du risque** et une revue de direction trimestrielle avec KPI (A1, A4).
3. **Engager un budget par classe :** S pour A1 et A4, M pour A2 et A3, L pour A5, à chiffrer avec les fournisseurs.
4. **Imposer au prestataire d'automatisme un avenant** (comptes nominatifs, MFA, révocation, notification d'incident) et réserver des fenêtres de maintenance pour les tests de restauration et le durcissement du pare-feu.

Limites : diagnostic pédagogique fondé sur des pièces fictives, sans visite sur site. La surveillance physique (A.7.4) et l'étendue de l'incident d'août 2026 restent à vérifier. Le profil devra être réévalué à six mois.